

NARRATIVA EXPLICATIVA

Encuesta FAICP 2025–2026: Por qué medimos lo que medimos (y cómo interpretarlo)

Contexto, Justificación y Hermenéutica del Marco de Indicadores

"Toda encuesta es también un acto político: decide qué vale la pena preguntar, a quién, y cómo interpretar las respuestas. Esta no es una excepción. Pero al menos tiene la honestidad de explicar sus decisiones."

Versión: 1.0 — Abril 2026 | **Audiencia:** Investigadores, decisores de política pública, CISOs, responsables de cumplimiento

1. POR QUÉ ESTA ENCUESTA AHORA

1.1. El Momento de Inflexión

En diciembre de 2025, el NIST publicó el borrador preliminar del **Cyber AI Profile (NIST IR 8596)**, el primer marco que traduce de forma sistemática las seis funciones del CSF 2.0 en indicadores específicos para entornos donde la IA es tanto activo como vector de amenaza. Era el reconocimiento institucional de algo que los profesionales ya sabían desde hace años: la IA no es un plugin del ecosistema de ciberseguridad. Es una reconfiguración estructural de ese ecosistema.

Al mismo tiempo, España completó un año singular: AESIA publicó 16 guías de cumplimiento del EU AI Act —las primeras de su tipo en Europa—, el Gobierno aprobó 1.157 millones de euros para ciberseguridad (el mayor esfuerzo histórico), INCIBE registró 122.223 incidentes (+26% interanual) y el 80% de los ataques de ingeniería social en la UE ya incorporaban componentes de IA generativa.

Esta encuesta nace en ese cruce de caminos: cuando las herramientas normativas existen, los recursos empiezan a fluir, pero la fotografía real del estado de implementación en el territorio aún no existe. Ese mapa es exactamente lo que se propone construir.

1.2. La Brecha que Justifica el Estudio

Los informes de madurez existentes —como el VI Indicador de Madurez del ISMS Forum España— ofrecen una visión nacional por sectores, pero sin desagregación territorial por CCAA. Los índices internacionales (Cisco CRI, WEF Outlook) ofrecen comparativas globales sin granularidad española. Y los marcos del regulador (EU AI Act, NIS2, ENS) establecen obligaciones sin medir su cumplimiento real.

Esta encuesta cierra ese espacio: mide el estado real, lo desagrega territorialmente y lo ancla a los marcos normativos y técnicos más recientes.

2. LOS TRES VECTORES DE RIESGO DEL CYBER AI PROFILE

El NIST IR 8596 organiza los indicadores en torno a tres vectores:

SECURE (Asegurar): Los riesgos *introducidos por* la IA en la organización. Cuando se despliega un sistema de IA, se abren nuevas superficies de ataque: el modelo puede ser envenenado, los datos de entrenamiento contaminados, la cadena de suministro comprometida. Este vector pregunta: ¿cómo gestionamos los riesgos que la propia IA trae consigo?

DEFEND (Defender): Las oportunidades de *usar* la IA para fortalecer la postura defensiva. La velocidad, capacidad de reconocimiento de patrones y escalabilidad de la IA pueden ponerse al servicio de la detección de amenazas, correlación de alertas y automatización de respuestas. ¿Estamos aprovechando la IA como aliada?

THWART (Contrarrestar): La resistencia al *uso adversarial* de la IA por atacantes: phishing hiperpersonalizado, malware polimórfico, deepfakes, explotación automatizada. ¿Estamos preparados para amenazas que se mueven a velocidad de máquina?

3. HERMENÉUTICA SECCIÓN POR SECCIÓN

3.1. Gobernanza: El Principio de Responsabilidad

La gobernanza se sitúa en primer lugar porque los controles técnicos son necesarios pero insuficientes si no existe una estructura de responsabilidad clara que los habilite. Sin gobernanza, la protección es anecdótica.

Las preguntas sobre política IA (P1.1) y cadena de suministro (P1.4) responden a los indicadores de alta prioridad del Cyber AI Profile (GV.OC-04, GV.SC-07). La pregunta sobre el Comité de IA (P1.5) refleja la recomendación del AI RMF de crear funciones de gobernanza multidisciplinares. El registro EU AI Act (P1.6) responde al Art. 49, que establece la obligación de registro para sistemas de alto riesgo.

3.2. Identificación: La Cartografía del Riesgo

No se puede proteger lo que no se conoce. El **AI-BOM** (P2.1) es la extensión lógica del SBOM al dominio de la IA: un inventario de modelos, datos de entrenamiento, dependencias y cadena de suministro. Su ausencia en la mayoría de organizaciones es, paradójicamente, el hallazgo más esperado de la encuesta.

La pregunta sobre amenazas adversariales externas (P2.3) introduce **MITRE ATLAS** como marco de referencia todavía relativamente desconocido en equipos de seguridad españoles.

3.3. Protección: El Doble Filo del Control

Los controles de protección en sistemas de IA tienen una característica irónica: el propio sistema puede ser tanto objeto de protección como vector de ataque. Un agente con exceso de privilegios (OWASP LLM06: Agencia Excesiva) no necesita ser comprometido externamente para causar daño; puede causarlo por diseño si sus capacidades de acción no están acotadas.

La gestión IAM para sistemas IA (P3.1) es una práctica sorprendentemente minoritaria incluso en organizaciones con alto nivel de madurez general: tratar a los sistemas de IA como identidades gestionables, con credenciales, permisos y ciclos de revisión propios.

3.4. Detección: Escuchar al Sistema

La detección en entornos IA añade una dimensión que no existe en la seguridad convencional: el **model drift**. Un modelo puede degradarse gradualmente de formas que no disparan alertas convencionales pero que alteran significativamente su comportamiento.

La monitorización de APIs externas (P4.1) aborda uno de los vectores más silenciosos de exfiltración: según el Cisco CRI 2025, el 60% de los equipos IT no tiene visibilidad sobre los prompts que sus empleados envían a herramientas GenAI externas.

3.5. Respuesta y Recuperación: La Anatomía del Incidente IA

La recuperación en contextos IA tiene una dimensión nueva: no es solo técnica sino también *epistémica*. Implica entender qué decisiones tomó el sistema comprometido durante el período de incidente, cuál fue su impacto en personas y procesos, y cómo restablecer la confianza en un sistema que demostró ser manipulable.

La pregunta P5.3 sobre plazos de notificación al EU AI Act y NIS2 es deliberadamente concreta: 15 días hábiles para incidentes graves al AESIA; 24 horas para notificación inicial NIS2. Son vinculantes, y su desconocimiento es en sí mismo un indicador de madurez.

4. CÓMO INTERPRETAR LOS RESULTADOS

4.1. El IGM como Fotografía, no Diagnóstico Completo

El IGM-FAICP resume una realidad compleja necesariamente. Dos organizaciones con IGM idéntico pueden tener perfiles de riesgo muy diferentes si una es fuerte en Detectar pero débil en Gobernar, y otra al revés. El análisis por función es al menos tan importante como el índice global.

4.2. La Trampa del Autodiagnóstico

Toda encuesta de autodiagnóstico mezcla tres categorías epistemológicamente distintas: lo que los respondientes *creen que hacen*, lo que *quisieran hacer*, y lo que *parece apropiado decir que hacen*.

Para mitigar el sesgo de deseabilidad social:

- Las preguntas están formuladas de forma que la respuesta "no tenemos esto implementado" sea explícitamente legítima
- El tono irónico de algunos enunciados invita a la honestidad más que la formulación aséptica
- Los resultados por CCAA y sector se contrastarán con fuentes externas (INCIBE, Cisco CRI, ENISA ETL)

4.3. La Brecha Percepción-Realidad

Estudios previos en seguridad de la información muestran consistentemente una brecha entre madurez autopercebida y madurez verificada externamente de entre 0.5 y 1.5 puntos (escala 1-5), siendo las organizaciones sistemáticamente más optimistas de lo que los datos de incidentes justifican.

5. COMPARATIVA INTERNACIONAL

Indicador	España 2025	Referencia Global	Fuente
Madurez "Mature" (Cisco CRI)	19%	4% media global	Cisco CRI 2025
AI Fortification Mature	7%	7%	Cisco CRI 2025
Identity Intelligence Mature	3%	6%	Cisco CRI 2025
Evaluación IA pre-despliegue	~35% (est.)	37%	WEF Outlook 2025
IA como herramienta ataque	80% (incidentes SE)	79% (UE)	ENISA ETL 2025

6. LIMITACIONES

- Sesgo de selección: Las organizaciones que responden tienden a ser más maduras. Los resultados sobrestimarán la madurez del universo.
- Sesgo de respondente: Quienes completan la encuesta tienen mayor conocimiento del tema que la media organizacional.
- Alcance territorial: La encuesta capta CCAA de sede principal, no operaciones multi-territoriales.
- Lo que no mide: La efectividad real de los controles (solo su existencia declarada), la calidad técnica de los sistemas IA, ni el nivel de riesgo inherente de los casos de uso específicos.

Kit FAICP 2025-2026 · Documento (c) · Versión 1.0 · Abril 2026